

RAG-Augmented Multi-Agent LLM Framework for Explainable Software Vulnerability Detection Using CWE Knowledge Bases

Richa Verma (25MCSS02) Advisor: Dr. Akshay Pandey

The steps running in one order

Where this fits

The separate pieces are a pattern checker, a CWE book, search, and a fixed answer form. This note connects them into one run.

No paid language model is used here. A template fills the form from the evidence. That template is a stand-in, so we can test the plumbing.

The idea we started with

A pipeline should be testable before it is expensive. If the steps are wired wrongly, a live model will hide the bug behind fluent text and a bill.

We also separated evidence from decision. The pattern checker is good at pointing at a line. It is bad at knowing whether that line is really a bug. Letting it both point and decide would freeze the weak checker into the final answer.

Why we chose this way

The order is fixed: mark lines, search the book using those lines, write the form, then check the form. Search uses the risky lines rather than the top of the file, because the top of a file is often imports and comments, not the bug.

The template is deterministic. Given the same evidence, it writes the same form. That makes failures reproducible. A live model is not reproducible in the same way, so it comes later.

We save a confidence number as a weighted mix of the model's confidence, the search strength, whether the checker agrees, and whether the form passed. We do not route on it. A number we have not calibrated is not a reason to skip the model or to trust the answer.

What we actually did

The run always starts by marking risky lines. Those marks are evidence. They include the file, the line numbers, and a short reason. They are not the final yes or no.

Next, search ranks CWE pages using the risky lines, not the whole file and not any hidden answer key. The pages include the description text, so a later writer can quote the book.

A template then fills the answer form. If the evidence is empty, the template is more likely to say the code is safe. If evidence exists, it leans on that evidence. This is a rule, not a judgment.

A checker then reads the form. The CWE must exist in the book. The cited lines must appear in the file. The fields must not contradict each other. A broken form fails.

If the written decision disagrees with the pattern checker, we keep a warning. We do not force the decision to match the checker. We also save a confidence number. We do not use that number to skip any step.

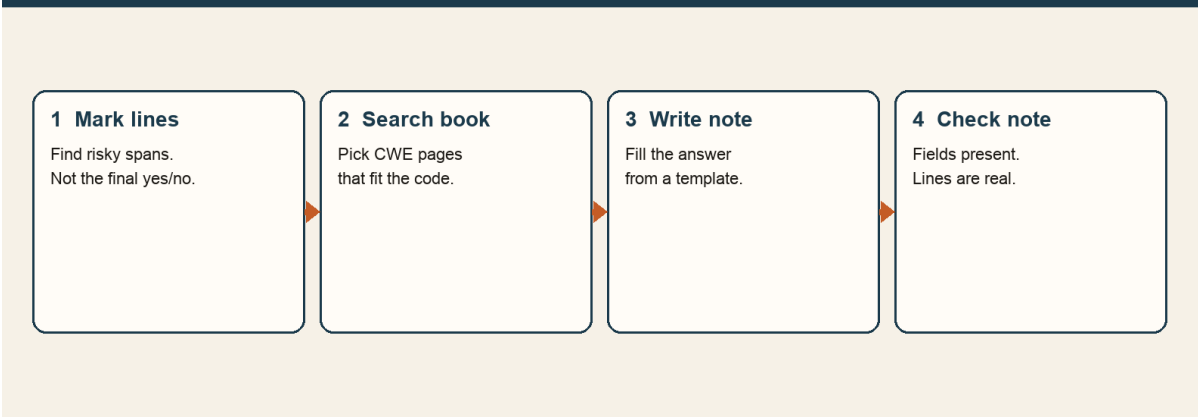
A concrete example

Take the SQL file again. Step 1 marks the lines that join the username into the query. Step 2 retrieves the CWE-89 page. Step 3, the template, fills the form from those marks and says the code is unsafe. Step 4 checks that CWE-89 is in the book and that the cited lines really are in the file.

The paired safe file may produce no marks. The template then leans toward safe. The checker still requires a complete form.

If the template said safe while step 1 had found marks, we would record a disagreement warning. We would not change the written decision to match the marks.

Picture



Four steps, always in this order. The first step does not make the final decision.

The numbers

Step	What it is allowed to do
Mark lines	Point at risky spans. Do not decide the case.
Search	Pick CWE pages from the book.
Write	Fill the form. Here, a template does this.
Check	Reject a broken or unsupported form.

On the four held-back practice files, this template path still matches the labels. That only repeats the easy result from the tiny set. It is not a new public score.

What we concluded, and why

The path is runnable from a command. The written note is still coming from rules, not from a model that can read a harder example.

The next piece of work is a set of files written to fool the pattern checker, and a live model that has to explain them. The conclusion here is that the path runs and the form can be checked. The template is a control, not a result we will defend.

What we are not saying

The template is not the system we want to rely on. A saved confidence number is not a real

probability.